

DIAGNÓSTICO DE PLATAFORMA — Miracle

(itsmiracleai.com.co)

Fecha: 2026-07-06 · **Alcance:** auditoría de solo lectura del repositorio (rama `main`, commit `521bb67`) con foco principal en la **plataforma del médico** (`/app/*`); la landing se cubre de forma secundaria. Los ratios de contraste fueron calculados con la fórmula WCAG 2.1 sobre los valores hex reales de `app/globals.css`. Lo no verificable se marca **[por confirmar]**.

1. Resumen ejecutivo

La base técnica es seria: Next.js 16 con doble verificación de sesión (proxy + layout), server actions que validan rol e inputs, RLS pensado por organización, onboarding de un solo paso y un design system coherente con modo oscuro. El problema no es la arquitectura: es que **la plataforma mezcla producto real con restos de demo** y tiene **cuatro agujeros que un piloto con médicos reales no perdona**:

- 1. **Las 3 APIs de IA son públicas:** sin sesión ni rate limiting, cualquiera puede quemar tus tokens de Anthropic y procesar datos por tu servidor (`app/api/chat/route.ts:22`).
- 2. **La consulta "en vivo" es una simulación** que guarda notas clínicas ficticias (cefalea hardcodeada) sobre pacientes reales, firmables y exportables (`app/app/consultas/en-vivo/page.tsx:21`).
- 3. **El botón primario falla contraste:** blanco sobre `#5b97f5` = 2.92:1 (mínimo 4.5:1); lo introdujo el commit `7054109` del 4 de julio que "aclaró el azul".
- 4. **Toda la plataforma se bloquea con un spinner** mientras el cliente descarga 300 consultas + 500 pacientes + todos los perfiles en cada entrada (`app/app/providers.tsx:159`).
- 5. **No existe recuperación de contraseña:** un médico que la olvide queda fuera hasta que un administrador lo rescate.

2. Hallazgos por categoría

Severidad: ● Crítico · ● Importante · ● Menor. Cada hallazgo: evidencia → por qué afecta al médico → recomendación.

2.1 Seguridad del ingreso y de los datos

#	SEV.	HALLAZGO
S1	●	APIs de IA sin autenticación. El matcher del proxy solo cubre <code>/app</code> , <code>/superadmin</code> y <code>/onboarding</code> (<code>proxy.ts:9</code>); <code>/api/chat</code> , <code>/api/generate-note</code> y <code>/api/parse-schedule</code> aceptan POST anónimos (<code>app/api/chat/route.ts:22</code> , <code>app/api/generate-note/route.ts:8</code> , <code>app/api/parse-schedule/route.ts:52</code>). Efecto: cualquiera en internet consume tus tokens (max_tokens 1024/2000/3000 por llamada) y puede canalizar datos clínicos por tu servidor. Recomendación: al inicio de cada <code>POST</code> , validar sesión con <code>supabase.auth.getClaims()</code> (mismo patrón de <code>lib/auth/server.ts:23</code>) y devolver 401; son ~6 líneas por ruta.

#	SEV.	HALLAZGO
S2	●	Sin rate limiting en las mismas rutas. Incluso autenticado, un médico (o un script con su cookie) puede disparar llamadas ilimitadas. Recomendación: límite simple por usuario (p. ej. 20 req/min en memoria o Vercel KV); no hace falta infra nueva para el piloto.
S3	●	Sin headers de seguridad. <code>next.config.ts</code> no define CSP, <code>X-Frame-Options</code> , <code>X-Content-Type-Options</code> ni HSTS. Efecto: la plataforma clínica puede embeberse en un iframe (clickjacking sobre el botón "Aprobar"). Recomendación: bloquee <code>headers()</code> en <code>next.config</code> con <code>frame-ancestors 'none'</code> , <code>nosniff</code> y HSTS.
S4	●	Política de contraseña débil y sin recuperación. Alta de médicos exige solo 8 caracteres sin complejidad (<code>app/superadmin/actions.ts:56</code>) y no existe flujo "olvidé mi contraseña" (ver I1). Recomendación: mínimo 10–12 caracteres + verificación contra contraseñas comunes; Supabase lo soporta en Auth settings sin código.
S5	●	La "firma" de la nota es un JSON sin garantías. <code>approveNote</code> guarda <code>{por, fecha}</code> sin re-autenticación ni hash del contenido firmado (<code>app/app/providers.tsx:399</code>). Efecto: como evidencia de firma de historia clínica (Res. 1995/1999, Ley 527) es frágil; además el actor puede ser un nombre ficticio de fallback ("Dra. Daniela Rincón", <code>providers.tsx:68</code>). Recomendación: firmar server-side (server action) registrando user id + hash SHA-256 del contenido de la nota en <code>audit_events</code> ; eliminar los nombres mock como fallback de actor.
S6	●	Se descargan todos los perfiles al navegador. <code>profiles.select("id, full_name, email")</code> sin filtro (<code>app/app/providers.tsx:171</code>). Efecto: los emails de todo el personal quedan en memoria del cliente; el alcance real depende de RLS [por confirmar]. Recomendación: traer solo los médicos referenciados por las consultas visibles, o exponer una vista sin email.
S7	●	Nombre del paciente viaja en la URL. "Iniciar consulta" desde la agenda navega a <code>/app/consultas/nueva?nombre=<paciente></code> (<code>components/app/AgendaHoy.tsx:264</code>). Efecto: dato personal de salud en historial del navegador y logs. Recomendación: pasar <code>appointment_id</code> y resolver el nombre en el servidor (además arregla F3).
✓	—	Bien resuelto: open redirect prevenido con <code>safeNext()</code> (<code>app/auth/callback/route.ts:4</code>), <code>localStorage</code> solo guarda el tema, <code>ANTHROPIC_API_KEY</code> nunca toca el cliente, y <code>lib/observability.ts</code> evita loguear PHI deliberadamente.

2.2 UX de ingreso y autenticación

#	SEV.	HALLAZGO
I1	●	No hay recuperación de contraseña. Ni link en <code>app/login/page.tsx</code> ni action de reset en <code>app/login/actions.ts</code> . Efecto: el médico que la olvide un lunes a las 7 a. m. no atiende con Miracle ese día; depende de que un humano lo rescate. Recomendación: <code>supabase.auth.resetPasswordForEmail()</code> + página <code>/auth/reset</code> ; es el quick win de mayor impacto en ingreso.
I2	●	Los deep links se pierden al entrar. El proxy guarda <code>?next=</code> al expulsar a login (<code>lib/supabase/proxy.ts:43</code>) pero <code>signInWithPassword</code> siempre redirige a <code>/app/dashboard</code> (<code>app/login/actions.ts:70</code>). Efecto: el médico que abre un enlace a una consulta concreta (desde WhatsApp del supervisor, p. ej.) termina en el dashboard y tiene que volver a buscarla. Recomendación: propagar <code>next</code> validado con el mismo <code>safeNext()</code> que ya existe.
I3	●	El login no da feedback al enviar. El submit no se deshabilita ni muestra spinner (no hay <code>useFormStatus</code> , <code>app/login/page.tsx:96</code>). Efecto: en la red hospitalaria lenta, el médico toca "Ingresar" 3 veces y no sabe si

#	SEV.	HALLAZGO
		funcionó. Recomendación: client component mínimo con <code>useFormStatus</code> → "Ingresando..." + <code>disabled</code> .
I4	●	Persistencia de sesión: correcta (cookies Supabase con refresh en proxy); no se fuerza re-login frecuente. Sin hallazgo — se documenta porque era pregunta explícita de la auditoría.
✓	—	El onboarding es ejemplar: 1 pantalla, < 1 minuto, defaults inteligentes (médico general, Colombia), campos opcionales marcados (app/onboarding/ClinicalOnboardingForm.tsx).

2.3 UX del flujo de trabajo diario (lo más importante)

Conteo de clics de la tarea principal (dashboard → nota generada): Iniciar consulta → (opcional: paciente/plantilla) → Empezar consulta → Finalizar y generar → detalle de nota. Son 3 clics obligatorios: bien. El problema no es la cantidad de pasos sino lo que hay dentro:

#	SEV.	HALLAZGO
F1	●	La consulta en vivo es teatro que produce registros clínicos reales. El transcript es un guion fijo de cefalea (app/app/consultas/en-vivo/page.tsx:21), la waveform y el "nivel de micrófono" son decorativos, y <code>buildDraft</code> fabrica una nota completa con códigos CIE-10 (en-vivo/page.tsx:30-122). Esa nota se persiste en <code>consultations</code> asociada a un paciente real y se puede firmar y "exportar" . El único aviso es un chip pequeño (línea 278). Efecto: un médico apurado firma una historia clínica falsa; en un piloto real eso es un incidente médico-legal y mata la confianza en el producto. Recomendación inmediata (sin esperar la transcripción real): (a) marcar estas consultas con <code>origen: "demo"</code> y excluirlas de "Por revisar y firmar", o (b) bloquear "Aprobar" cuando el transcript sea el simulado, con un banner explícito. La grabación real vía API Miracle es la solución de fondo [pendiente de la integración planeada] .
F2	●	Un spinner bloquea TODA la plataforma en cada entrada. <code>MiracleProvider</code> no renderiza nada hasta descargar 300 consultas <code>select("*")</code> (con <code>note</code> y <code>transcript</code> JSON completos) + 500 pacientes + todos los perfiles + auditoría (app/app/providers.tsx:159-209 , gate en línea 537). Efecto: en el celular con 3G del hospital, el médico mira una ruedita; y las páginas RSC (consultas, pacientes, notas) ya paginan en servidor , así que el store duplica el trabajo. Recomendación: reducir la carga inicial a lo que el dashboard usa (consultas de hoy + pendientes, ~20 filas con columnas mínimas) y dejar el detalle para fetch por id; eliminar el gate global (render inmediato con skeletons).
F3	●	"Iniciar consulta" desde la agenda pierde al paciente. El <code>?nombre=</code> solo prellena el buscador (app/app/consultas/nueva/page.tsx:45); si el médico no pulsa "Crear paciente «X»" o no selecciona uno, la consulta se crea sin paciente y el nombre desaparece en <code>/en-vivo</code> . Efecto: el flujo estrella de la agenda (feature del 4 de julio) promete continuidad y no la cumple; el médico debe re-teclear. Recomendación: pasar <code>appointment_id</code> , auto-seleccionar si hay match exacto por nombre/documento y ofrecer "crear paciente" en un clic; al firmar la nota, marcar la cita como atendida (hoy son dos acciones separadas).
F4	●	Eliminar cita: sin confirmación, botón de 28 px pegado a los demás. <code>eliminar()</code> borra directo (components/app/AgendaHoy.tsx:134-144); Play/Check/Trash son <code>h-7 w-7</code> (28 px) con <code>gap-0.5</code> (líneas 262-299). Efecto: con el pulgar, "iniciar consulta" y "borrar cita" están a 2 mm; el borrado es irreversible y silencioso. Recomendación: confirmación ligera (toast "Cita eliminada — Deshacer" con ventana de 5 s) + subir targets a ≥ 40 px.

#	SEV.	HALLAZGO
F5	●	"Por revisar y firmar" renderiza TODO sin límite ni orden visible. <code>pendientes.map(...)</code> completo (app/app/dashboard/page.tsx:101-116). Efecto: un médico con 40 borradores recibe un muro de tarjetas en su pantalla principal; lo importante (la más vieja o la de hoy) no destaca. Recomendación: mostrar 5 ordenadas por antigüedad + "Ver las N restantes" hacia <code>/app/consultas?estado=borrador</code> .
F6	●	No hay cierre de sesión en móvil ni tablet. El botón "Salir" es <code>hidden lg:inline</code> (components/app/AppShell.tsx:107), el avatar no es interactivo y el drawer móvil no lo incluye (components/app/AppSidebar.tsx). Efecto: en equipos compartidos de consultorio, la sesión del médico queda abierta para el siguiente. Recomendación: ítem "Cerrar sesión" al pie del sidebar/drawer (visible en todos los tamaños).
F7	●	No hay búsqueda en móvil. El trigger del Command Palette es <code>hidden sm:flex</code> (components/app/AppShell.tsx:78) y <code>⌘K</code> no existe en táctil. Efecto: encontrar un paciente en el celular exige navegar a Pacientes y usar su filtro; son 3 pasos para la acción más frecuente. Recomendación: icono de lupa en el header móvil que abra el mismo <code>CommandPalette</code> .
F8	●	Guardado optimista sin red de seguridad. <code>persist()</code> es fire-and-forget: si el UPDATE falla, la UI ya mostró éxito y solo aparece un toast genérico; no hay retry ni cola (app/app/providers.tsx:233-253). Efecto: el médico edita la nota en el ascensor, pierde señal, y sus cambios se esfuman creyendo que quedaron. Recomendación: reintento con backoff + indicador persistente "cambios sin sincronizar" mientras haya escrituras pendientes.
F9	●	"Exportar a HC" es un placebo. Solo cambia el estado y el toast afirma "Copiada al sistema de historia clínica" (app/app/providers.tsx:416-427). Efecto: el médico cree que la nota ya está en su HIS; cuando descubra que no, la confianza se rompe. Recomendación: mientras no exista integración, que copie la nota formateada al portapapeles (ya existe <code>copyResumen</code>) y el copy diga la verdad: "Nota copiada para pegar en su sistema".
F10	●	Se inventan datos clínicos por defecto. Todo paciente nuevo nace <code>sexo: "F"</code> , <code>edad: 0</code> (app/app/providers.tsx:315-326 , consultas/nueva/page.tsx:56) y la nota luego redacta "Paciente femenina de..." (en-vivo/page.tsx:47). Efecto: un dato demográfico fabricado dentro de una historia clínica. Recomendación: <code>sexo</code> nullable ("Sin registrar") y que la nota lo omita si falta.
F11	●	Salir de la consulta en vivo no avisa. Sin guard de navegación: back o cerrar pestaña pierde la sesión de captura sin confirmación (app/app/consultas/en-vivo/page.tsx). Recomendación: <code>beforeunload</code> + confirmación al navegar mientras <code>seconds > 0</code> .
F12	●	El panel del administrador muestra KPIs ficticios como reales. <code>managementKpis</code> , <code>weeklyNotes</code> , <code>adoptionByService</code> vienen de <code>lib/mock</code> (app/app/dashboard/page.tsx:209-247); "Reportes" delega en el mismo store. Efecto: un director médico toma decisiones (o pierde la confianza) sobre datos inventados. Recomendación: calcular los 4 KPIs con queries reales (ya existen RPCs de conteo para notas/auditoría) o etiquetar el panel entero como "Datos de demostración".

2.4 UI y percepción visual

Ratios calculados sobre [app/globals.css](#) (modo claro salvo indicación):

#	SEV.	PAR	RATIO	DÓNDE GOLPEA
U1	●	Blanco sobre <code>--color-accent</code> <code>#5b97f5</code>	2.92:1 (mín. 4.5, ni 3:1 de large)	Todos los botones primarios: "Ingresar" (login), "Empezar consulta", "Agendar", "Analizar horario", enviar en chat. Regresión del commit <code>7054109</code> (2026-07-04).

#	SEV.	PAR	RATIO	DÓNDE GOLPEA
U2	●	text-accent #5b97f5 sobre blanco	2.92:1	Links "Ver todos", "Solicitar acceso institucional", eyebrows, iconos de acción de la agenda.
U3	●	--color-muted #6b7a8f sobre blanco / pearl / ice-soft	4.37 / 4.11 / 4.03	El color de texto más usado de la plataforma: hints, subtítulos, timestamps, estados vacíos. Falla AA para texto normal en los tres fondos.
U4	●	warning #b45309 sobre #fdeecf (4.38) y danger #c0392b sobre #fbe3df (4.44)	límite	Avisos de error del login, chip "Grabando".
U5	●	Dark: blanco sobre accent #4f93f5	3.08	Botones primarios en modo oscuro.
✓	—	Sidebar (mist/night 8.49), texto principal (ink 17.96), badges (accent-ink/accent-soft 7.12), success/warning como texto plano: todos pasan. El modo oscuro en general está mejor calibrado que el claro.		

Recomendación U1–U3 (una sola edición): volver el acento de los CTA a un azul $\geq 4.5:1$ con blanco (p. ej. #2f6fe0 $\approx 4.6:1$, o el accent-hover oscurecido) y subir --color-muted a #5d6b80 ($\approx 5.2:1$ sobre blanco). Si el azul claro #5b97f5 gusta como identidad, úsese en fondos suaves/bordes, no como fondo de texto blanco.

#	SEV.	OTROS HALLAZGOS VISUALES
U6	●	Inconsistencia de formas y alturas de control: botones rounded-full conviven con inputs rounded-md y paddings dispares (py-1.5 , py-2 , py-2.5 , py-3) — compárese AgendaHoy.tsx:165 vs login/page.tsx:96 vs ui/Button.tsx . No es grave, pero un Button único con tallas fijas (sm/md/lg) eliminaría la deriva.
U7	●	Restos de plantilla en public/ : next.svg , vercel.svg , globe.svg , window.svg , file.svg siguen desplegándose. Aseo de percepción profesional.
U8	●	Jerarquía del dashboard correcta (hero navy con CTA único destaca bien), pero el chip "Captura simulada" de en-vivo (línea 278) es el aviso más importante de esa pantalla y el menos visible (texto text-xs ámbar sobre crema, 4.38:1). Si la simulación se queda un tiempo, ese aviso debe ser un banner de ancho completo.

Percepción profesional: la base transmite seriedad clínica (paleta sobria, radios generosos, tipografía Schibsted/Inter, dark mode cuidado). Lo que hoy la baja de nivel: KPIs ilustrativos (F12), textos que prometen cosas que no pasan (F9, C1) y el contraste débil del acento (U1). Es pulido de honestidad más que de estética.

2.5 Accesibilidad

#	SEV.	HALLAZGO
A1	●	El estado de grabación no se anuncia. "Grabando · MM:SS / En pausa" es solo visual (app/app/consultas/en-vivo/page.tsx:271); sin aria-live , un médico con lector de pantalla no sabe si la captura corre — crítico

#	SEV.	HALLAZGO
		cuando la grabación sea real. Recomendación: <code>role="status" aria-live="polite"</code> en el chip (anunciando cambios de estado, no cada segundo).
A2	●	Targets táctiles bajo mínimo: acciones de cita 28 px (AgendaHoy.tsx:262-299), enviar del chat 36 px (MedicalChat.tsx:166), iconos del header 36 px (AppShell.tsx:92). WCAG/plataformas móviles piden ≥ 44 px.
A3	●	Modales y dropdowns sin focus trap ni Escape: <code>ImportarFotoModal</code> (AgendaHoy.tsx:445) y <code>NotificationsBell</code> no cierran con Escape ni retienen el foco; <code>CommandPalette</code> sí maneja Escape. Con teclado se puede tabular "detrás" del modal.
A4	●	Inputs sin nombre accesible: búsqueda de paciente (consultas/nueva/page.tsx:223) e input del chat (MedicalChat.tsx:156) solo tienen placeholder; el <code>Toggle</code> de configuración es <code>role="switch"</code> sin <code>aria-label</code> (app/app/configuracion/ConfiguracionForm.tsx:131).
A5	●	La waveform ignora <code>prefers-reduced-motion</code> (anima por JS, components/app/Waveform.tsx); el CSS global sí lo respeta para <code>.rise/.float</code> (globals.css:231).
✓	—	Bien: <code><html lang="es"></code> , <code>:focus-visible</code> global (globals.css:175), labels correctos en login/onboarding, <code>aria-label</code> en todas las acciones de la agenda, toasts con <code>role="status"</code> , nav con <code>aria-label</code> .

2.6 Performance y consumo

#	SEV.	HALLAZGO
P1	●	La carga inicial del store es el mayor costo de toda la app (mismo F2, aquí en clave de costo): <code>select("*")</code> trae <code>note</code> + <code>transcript</code> + <code>codigos</code> JSON de 300 consultas que el dashboard no necesita (app/app/providers.tsx:160-209). Cada refresh re-descarga todo (sin caché). Es ancho de banda del médico y lecturas de Supabase multiplicadas por sesión. Recomendación: columnas explícitas y ~20 filas para el dashboard; detalle bajo demanda.
P2	●	Sin prompt caching en Anthropic. El system prompt se reenvía completo en cada llamada de chat/nota/agenda (api/chat/route.ts:64) y el chat reenvía hasta 20 mensajes por turno. Recomendación: <code>cache_control: {type: "ephemeral"}</code> en el bloque system (una línea por ruta, ~90 % de descuento sobre esos tokens de entrada en hits).
P3	●	El chat no hace streaming: el médico espera la respuesta completa en silencio (api/chat/route.ts:54 , MedicalChat.tsx:36). Para respuestas clínicas largas la percepción de lentitud es alta. Recomendación: <code>stream: true</code> + lectura incremental; sin costo extra.
P4	●	<code>parse-schedule</code> sin deduplicación: re-analizar la misma foto vuelve a pagar visión completa. Un hash del base64 en memoria corta el caso "doble clic en Analizar".
P5	●	Landing: imágenes JPG (~256 KB total) ya pasan por <code>next/image</code> con <code>deviceSizes</code> capados (next.config.ts) — correcto; margen menor comprimiendo a WebP en origen.
✓	—	Bien: las páginas RSC (consultas, pacientes, notas, auditoría) paginan con <code>range()</code> y RPCs de conteo — la migración <code>perf(a2)</code> del 3 de julio hizo lo correcto; <code>motion</code> solo carga en la landing; los <code>"use client"</code> de la plataforma están justificados.

2.7 Copy y microcopy

#	SEV.	HALLAZGO
C1	●	Promesas de privacidad sobre un audio que no existe: "El audio no se conserva tras generar la nota" (en-vivo/page.tsx:379 , consultas/[id]/page.tsx:599). Hoy es vacío y, cuando la grabación sea real, será un compromiso legal — que el texto nazca del comportamiento real, no antes.
C2	●	Toasts que afirman lo que no pasó: "Nota exportada a la historia clínica" (providers.tsx:424) sin integración alguna. Cambiar a "Nota marcada como exportada" o implementar la copia real (F9).
C3	●	Jerga técnica frente al médico: el chat sin configurar responde "falta configurar la clave ANTHROPIC_API_KEY en el servidor" (api/chat/route.ts:48); y "Consulta no encontrada... reiniciada en la demo" (consultas/[id]/page.tsx:67) habla de "demo" en producción. Reescribir en lenguaje de usuario ("El asistente aún no está habilitado para tu institución").
C4	●	"Regrabar" no regraba: el icono de micrófono en el detalle (consultas/[id]/page.tsx:206-219) inicia una consulta nueva — puede duplicar registros sin que el médico lo entienda. Renombrar a "Nueva captura" o eliminar hasta que exista de verdad.
✓	—	La landing pasa la prueba de los 5 segundos: "Mire al paciente. Miracle se encarga del resto." + subtítulo concreto; trato de "usted" consistente; chips CIE-10/CUPS/RIPS hablan el idioma del sector; el disclaimer de IA en la nota ("Verifique la información...") está bien planteado. Los mensajes de error del login son claros y humanos.

3. Propuestas de funcionalidades nuevas

Pensadas para el médico colombiano con poco tiempo, priorizando consumo cero de IA:

#	FUNCIONALIDAD	PROBLEMA REAL QUE RESUELVE	ESFUERZO	IMPACTO	CONSUMO
N1	Recuperar contraseña (<code>resetPasswordForEmail</code> + página de reset)	Médico bloqueado fuera de la plataforma sin depender del admin	Bajo	Alto	Cero
N2	Cita → consulta con continuidad real (pasar <code>appointment_id</code> , autoseleccionar paciente, marcar atendida al firmar)	Hoy el prefill se pierde y hay que re-teclear y cerrar la cita a mano (F3)	Bajo	Alto	Cero
N3	Frases rápidas personales (snippets por médico para Plan/Recomendaciones, insertables desde la edición de nota; tabla pequeña o JSON en perfil)	Lo que más re-escribe un médico son sus propias indicaciones de siempre	Bajo–Medio	Alto	Cero (sin IA)
N4	"Traer última nota" del paciente (duplicar secciones de la consulta previa como punto de partida en control/seguimiento)	Consultas de control repiten 80 % de la nota anterior	Bajo	Alto	Cero (datos ya en BD)

#	FUNCIONALIDAD	PROBLEMA REAL QUE RESUELVE	ESFUERZO	IMPACTO	CONSUMO
N5	Modo fin de jornada (cola de pendientes en pantalla completa: revisar → aprobar con un tap, una nota tras otra)	Firmar 15 notas acumuladas hoy exige entrar y salir de cada detalle	Medio	Alto	Cero
N6	Búsqueda en móvil + acciones rápidas (lupa en header que abre el CommandPalette existente)	En celular no hay forma directa de llegar a un paciente (F7)	Bajo	Medio	Cero
N7	Aviso de notas envejecidas (banner local "3 notas llevan >48 h sin firmar" con link filtrado)	El borrador olvidado es el riesgo de calidad documental #1	Bajo	Medio	Cero
N8	Exportar codificación RIPS-ready (CSV local de códigos aceptados por rango de fechas, desde Reportes)	El admin hoy no puede sacar nada tangible del sistema	Medio	Medio	Cero
N9	Streaming + caché del asistente (respuestas token a token; caché local de las 3 sugerencias predefinidas)	El chat se siente lento y las preguntas sugeridas repagan tokens idénticos	Bajo–Medio	Medio	Ahorra
N10	Borrador a prueba de señal (persistir la nota en edición en IndexedDB y sincronizar al volver la red, con indicador "sin sincronizar")	Wifi hospitalario intermitente + guardado fire-and-forget = notas perdidas (F8)	Medio–Alto	Alto	Cero

4. Matriz de priorización

Quick wins (alto impacto / bajo esfuerzo) — el orden sugerido de ejecución: 1. **Autenticar las 3 APIs de IA** (S1) — pocas líneas por ruta; cierra fuga de dinero y de datos. 2. **Corregir tokens de color** `--color-accent` (para CTAs) y `--color-muted` (U1–U3) — una edición en `globals.css` arregla el contraste de toda la app. 3. **Recuperación de contraseña** (I1/N1). 4. **Neutralizar la demo peligrosa** (F1, versión mínima): excluir consultas simuladas de la cola de firma + banner visible. 5. Confirmar/deshacer al eliminar cita + targets ≥ 40 px (F4, A2). 6. Copy honesto en export/asistente ("marcada como exportada", sin jerga de API) (C2, C3). 7. `useFormStatus` en login (I3) y logout visible en móvil (F6). 8. Límite + orden en "Por revisar y firmar" (F5).

Mejoras estructurales (semanas): - Desmontar el store global: dashboard con datos mínimos, detalle por id, sin spinner bloqueante (F2/P1). - Guardado con reintentos e indicador de sincronización (F8 → N10 como versión completa). - Firma server-side con hash + auditoría sin nombres mock (S5). - Headers de seguridad + rate limiting (S2, S3). - Focus trap/Escapes en modales, `aria-live` en grabación (A1, A3). - Streaming + prompt caching en las rutas de IA (P2, P3, N9). - KPIs reales (o etiquetados) para admin/supervisor (F12).

Apuestas a futuro: - Grabación y transcripción reales (integración API Miracle) — desbloquea el corazón del producto y vuelve verdaderos C1/F1. - Integración de exportación a HIS/RIPS (F9/N8 completo). - Offline-first

integral y snippets con sugerencias inteligentes (N3 + IA local opcional).

5. Preguntas abiertas (antes de la fase 2)

1. **¿Cuándo llega la transcripción real (API Miracle)?** Define si F1 se resuelve con un feature flag que oculte `/consultas/en-vivo` o con la versión mínima (banner + exclusión de firma). *Contexto: la integración con la API externa ya está planeada pero tiene huecos pendientes (contrato JSON de la nota, endpoint de chat).*
 2. **¿Hay médicos reales usando producción hoy?** Cambia la urgencia de S1 (APIs abiertas) y F1 (notas ficticias firmables) de "esta semana" a "hoy".
 3. **RLS en `patients` / `consultations` / `profiles` : ¿está activo y filtrando por organización en el proyecto Supabase real?** No pude verificarlo desde el repo (el MCP apunta a otro proyecto). Si `profiles` no filtra, S6 sube a crítico. **[por confirmar]**
 4. **¿El rol admin/supervisor participará en el piloto?** Si sí, F12 (KPIs mock) debe entrar en quick wins; si no, basta etiquetarlos como demo.
 5. **Presupuesto de infra para rate limiting:** ¿límite simple en memoria por instancia es aceptable para el piloto, o quieren Upstash/Vercel KV desde ya?
 6. **La migración `appointments` y `ANTHROPIC_API_KEY` en Vercel:** siguen pendientes de aplicar/verificar según el estado del repo — sin eso, la agenda muestra su aviso de migración y la importación por foto degrada a manual.
-

Auditoría generada el 2026-07-06 sobre el código en `main@521bb67`. Ningún archivo de la aplicación fue modificado.